Risk Register

R-001

Privileged access and MFA

Residual estimate

High (15)

Related control

CTL-05

Status

Open

The risk and its impact

Risk scenario

Unauthorized use of a privileged account could provide administrative access to systems supporting payment processing.

Why it matters

Unauthorized administrative access could expose sensitive information, alter system configurations, or disrupt payment-processing operations.

Cause or gap

PA-010 has an unassigned owner and missing approval reference; MFA enforcement and its login outcome are unknown. PA-012 has unclear ownership, no supplied approval record, and an undocumented authentication method.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

PA-001–PA-009 have named owners, approvals, and MFA enforcement recorded. PA-010 has MFA configured, but enforcement is unknown. These records do not establish effective safeguards for PA-010 or PA-012.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible privileged-account misuse while authorization and authentication safeguards remain uncertain. Impact 5 assumes administrative compromise could seriously affect sensitive systems and payments. Actual permissions, exposure, and safeguard effectiveness require verification; no residual reduction is credited.

What needs to happen

Risk response

Reduce

Required action

Assign and validate PA-010 ownership and approval; verify and enforce applicable MFA. Validate PA-012 authorization, ownership, and service-account authentication safeguards. Retain supporting configuration and authentication records.

Accountable owner

Identity and Access Management / Privileged Access Owner

Target date

11/13/2026

Evidence references

E-005-01; E-005-02; E-005-03; E-005-05

R-002

Third-party risk management

Residual estimate

High (15)

Related control	Status
CTL-03	Open

The risk and its impact

Risk scenario

Incomplete oversight of the critical payment processor could leave vendor deficiencies or incident-response responsibilities unresolved, disrupting payment services or delaying incident response.

Why it matters

A processor outage or security incident could disrupt transactions and create financial, operational, and reputational harm.

Cause or gap

The processor is classified Critical, but its current assurance report is requested and not attached. Incident-notification terms remain Open without documented risk acceptance.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

The processor is included in the vendor inventory as Critical. Security owns the assurance review, and Legal / Security owns notification terms. The review remains In progress and the terms action remains Open.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible vendor-related disruption with incomplete assurance and unresolved notification terms. Impact 5 assumes the critical processor dependency could materially interrupt payments. No complete vendor population, contractual detail, or verified safeguard effectiveness supports a residual reduction.

What needs to happen

Risk response

Reduce

Required action

Obtain and evaluate the processor’s current assurance report. Resolve incident-notification terms or document an authorized risk decision. Define owners and target dates for remaining follow-up.

Accountable owner	Target date
Security, with Legal/Security support for incident notification terms.	11/27/2026

Evidence references

E-003-01; E-003-02

R-003

Asset inventory and classification

Residual estimate

High (15)

Related control	Status
CTL-02	Open

The risk and its impact

Risk scenario
A CI/CD platform without clear ownership or review accountability could permit unauthorized or insecure changes to payment code.

Why it matters
Unauthorized or insecure payment-code changes could disrupt transaction processing, expose information, or cause financial and reputational harm.

Cause or gap
The CI/CD platform is inventoried as able to change payment code, but its owner and last-review date are blank. Complete inventory coverage is not established.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards
The inventory identifies the CI/CD platform and its payment-code function. It does not establish assigned ownership or completed review for that platform.

Basis for the score
Assumptions and limits
Likelihood 3 reflects plausible misuse or unmanaged change where CI/CD accountability is missing. Impact 5 assumes deployment capability could affect payment-code security or availability. Actual access, technical safeguards, review history, and complete inventory coverage are unverified.

What needs to happen

Risk response
Reduce

Required action
Assign a CI/CD asset owner. Complete and document an asset review, define periodic review requirements, and reconcile relevant assets to payment flows and administrative paths.

Accountable owner	Target date
Engineering Leadership / Designated CI/CD asset owner	11/27/2026

Evidence references
E-002-01

R-004

Residual estimate

Access lifecycle and access reviews

High (16)

Related control

CTL-04

Status

Open

The risk and its impact

Risk scenario

Failure to reconcile termination records with account status could leave former personnel with unauthorized access to business systems or information.

Why it matters

Unauthorized access by former personnel could expose information, enable inappropriate activity, or disrupt business operations.

Cause or gap

USR-023 and USR-024 have Status Terminated, while their Approval field says Active in export. Both are explicitly Not reviewed in the quarterly sample, and follow-up is not attached. Actual enabled-account status is unverified.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	4	4	16	High
Residual estimate	4	4	16	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

USR-001 and USR-002 have Approval Yes and Reviewed / Signed off statuses. The two former-user entries remain unreviewed, with unresolved account-state annotations and no supplied follow-up.

Basis for the score

Assumptions and limits

Likelihood 4 is a conservative estimate pending reconciliation of two terminated identities marked Active in export and explicitly unreviewed. Impact 4 assumes misuse could expose business information or disrupt relevant systems. Actual enabled state, permissions, and termination dates are unverified.

What needs to happen

Risk response

Reduce

Required action

Reconcile USR-023 and USR-024 to identity-provider and application account states. Remove access where no longer authorized, complete their reviews, and retain follow-up decisions and supporting records.

Accountable owner

Access Management with HR and any relevant system owners

Target date

11/13/2026

Evidence references

E-004-01; E-004-02

R-005

Change management

Residual estimate

High (16)

Related control

CTL-06

Status

Open

The risk and its impact

Risk scenario

Changes deployed without timely authorization, adequate testing, or appropriate emergency review could introduce insecure or unstable functionality into production.

Why it matters

Insecure or unstable production changes could disrupt services, introduce vulnerabilities, or affect payment-processing operations.

Cause or gap

CHG-101 records approval After deployment. CHG-102 test evidence is Missing. CHG-103 testing is Not shown and post-implementation review is not evidenced.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	4	4	16	High
Residual estimate	4	4	16	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

CHG-100 records pre-deployment approval and testing, and CHG-103 follows an emergency path. The four-change summary does not establish consistent approval, testing, or emergency-review effectiveness. Referenced attachments were not supplied.

Basis for the score

Assumptions and limits

Likelihood 4 reflects late approval and incomplete testing/review records in the four-change sample. Impact 4 assumes production changes could materially disrupt payments. Residual likelihood is retained at 4, revised from 3: one complete change does not justify a reduction. This is a conservative qualitative estimate.

What needs to happen

Risk response

Reduce

Required action

Require normal-change approval before deployment and retain testing records. Obtain CHG-102/103 testing and CHG-103 emergency-review evidence. Investigate CHG-101 approval timing and document resolution of the sampled exceptions.

Accountable owner

Change management owner, accompanied with Engineering support

Target date

11/27/2026

Evidence references

E-006-01; E-006-02

R-006

Vulnerability management

Residual estimate

Critical (20)

Related control	Status
CTL-07	Open

The risk and its impact

Risk scenario

Unresolved vulnerabilities and incomplete scanning coverage could leave payment-supporting systems exposed to exploitation and unauthorized access.

Why it matters

Exploitation could compromise sensitive systems or information, disrupt payment services, and cause financial, operational, and reputational harm.

Cause or gap

VUL-01 and VUL-02 are High and Open. VUL-02 has an October 1 target and is marked overdue. The Admin host is outside scan scope. VUL-03 has an expired exception with no recorded reassessment.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	4	5	20	Critical
Residual estimate	4	5	20	Critical

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

Payment API and Cloud DB are recorded as scanned. VUL-01 has an assigned ticket and an October 20 target, which was not overdue at the October 15 cutoff. VUL-02 is overdue; full scan coverage and remediation closure are unverified.

Basis for the score

Assumptions and limits

Likelihood 4 reflects open High findings, overdue VUL-02, and an expired exception. Impact 5 assumes exploitation of the payment API or Cloud DB could severely affect information or payments. Findings are assessed at the declared October 15 cutoff; exploitability, scan dates, full coverage, and later remediation remain unverified.

What needs to happen

Risk response

Reduce

Required action

Resolve or formally mitigate VUL-02 and document a current target. Verify VUL-01’s outcome against its October 20 target. Confirm the Admin host’s relevance and include it in scanning where required. Reassess VUL-03 and document any renewed exception approval and safeguards.

Accountable owner	Target date
Vulnerability Management Owner with affected system owners	11/13/2026

Evidence references

E-007-01; E-007-02

R-007

Logging and monitoring

Residual estimate

High (15)

Related control	Status
CTL-08	Open

The risk and its impact

Risk scenario

Incomplete security logging and unsupported alert-triage decisions could delay incident detection, investigation, and response.

Why it matters

Delayed detection or investigation could allow an incident to continue, affecting payment services, sensitive information, or business operations.

Cause or gap

Database logging, centralization, and retention are Unknown. The Support console has a row marked Not listed / Check scope. High-severity ALT-01 is Closed benign with No supporting notes.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

Payment API and identity provider are recorded as logging centrally with 90-day retention. ALT-02 is marked Investigated / Analyst notes attached, but those notes were not supplied separately. Actual logging and review effectiveness remain unverified.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible delayed detection where coverage is unknown and a High alert lacks supporting closure notes. Impact 5 assumes a prolonged incident affecting critical payment systems could have severe consequences. No undetected breach is established, and actual logging, retention, and review quality remain unverified.

What needs to happen

Risk response

Reduce

Required action

Obtain ALT-01 investigation rationale and notes. Verify database logging and Support console scope/configuration. Define retention requirements and test actual retention. Inspect referenced analyst notes and representative source logs.

Accountable owner	Target date
Security Operations / Logging and Monitoring owner	11/27/2026

Evidence references

E-008-01; E-008-02

R-008

Incident response

Residual estimate

High (15)

Related control	Status
CTL-09	Open

The risk and its impact

Risk scenario

Incomplete incident follow-up, unresolved exercise actions, and generic processor-coordination procedures could delay containment, recovery, or external coordination.

Why it matters

Delayed or ineffective response could prolong service disruption, increase security exposure, and affect payment operations and stakeholder confidence.

Cause or gap

INC-01 is Closed with root-cause analysis missing. TTX-01 is Completed, but two actions remain Open and no retest is recorded. Processor-coordination steps in the plan summary are generic.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

The plan summary identifies response, escalation, and communication roles. A tabletop exercise is recorded as completed. Underlying incident, exercise, and action-closure records were not supplied.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible response delays from incomplete coordination and follow-up. Impact 5 assumes a significant incident could severely disrupt payment services. Actual incident scope, action due dates, and response performance are unverified; Open actions are not automatically overdue.

What needs to happen

Risk response

Reduce

Required action

Document INC-01 root-cause analysis. Assign owners and dates for TTX-01 actions, retain closure evidence, and document a retest where appropriate. Specify processor contacts, escalation responsibilities, and coordination steps.

Accountable owner	Target date
Incident Response Owner, with Security and payment processor relationship owners.	11/27/2026

Evidence references

E-009-01; E-009-02

R-009

Sensitive data protection

Residual estimate

High (15)

Related control	Status
CTL-10	Open

The risk and its impact

Risk scenario

Incomplete identification of sensitive-data flows and inadequate storage or retention safeguards could leave payment or customer information insufficiently protected.

Why it matters

Inadequate protection could result in unauthorized disclosure, excessive retention, contractual or regulatory exposure, and reputational harm.

Cause or gap

One Support export path is unmapped. Analytics-store encryption at rest is Unknown / Not evidenced. The export sample lacks a retention date and notes two exports without approved retention rationale.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

The primary payment flow is described and the processor connection is listed as TLS 1.2+. These summaries do not establish complete flow coverage, analytics encryption at rest, or effective export-retention controls.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible data exposure with an unmapped flow and incomplete retention documentation. Impact 5 assumes sensitive payment or customer information could be extensively compromised. Data volumes, technical settings, and actual retention execution are unverified; Unknown encryption does not mean encryption is disabled.

What needs to happen

Risk response

Reduce

Required action

Map the Support export path and data elements. Inspect processor and analytics encryption configurations. Approve export-retention requirements and dates, verify execution, and retain supporting records.

Accountable owner	Target date
Data Protection Owner, with Analytics and Support Operations owners.	11/27/2026

Evidence references

E-010-01; E-010-02

R-010

Backup and recovery

Residual estimate

High (15)

Related control	Status
CTL-11	Open

The risk and its impact

Risk scenario

Incomplete backup coverage or insufficiently validated restoration could delay recovery of critical systems after an outage or security incident.

Why it matters

Delayed recovery or information loss could prolong payment-service disruption and increase operational, financial, and reputational harm.

Cause or gap

Identity-configuration backup coverage is unknown. A Payment DB restore is recorded as successful but was not compared with an approved recovery-time objective. One of four administrators lacks recent access-review evidence.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

Daily backups for Payment database and Configuration store are reported as successful, as is one Payment DB restore. Complete coverage, measured recovery performance, and full administrator-review coverage are not established.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible recovery difficulty where coverage and recovery performance are unverified. Impact 5 assumes critical payment systems could suffer prolonged outage or information loss. Summary successes do not establish full coverage or recovery capability; no backup failure or inappropriate access is proved.

What needs to happen

Risk response

Reduce

Required action

Verify identity-configuration backup coverage. Obtain dated backup and restore records and approved recovery objectives. Compare measured restore performance with those objectives. Complete the missing administrator review and document its outcome.

Accountable owner	Target date
Backup and disaster recovery owner; with identity and system owners	11/27/2026

Evidence references

E-011-01; E-011-02

R-011

Payment transaction integrity

Residual estimate

High (15)

Related control	Status
CTL-12	Open

The risk and its impact

Risk scenario

Unresolved reconciliation exceptions or insufficiently reviewed payment-routing changes could allow transaction errors or unauthorized changes to remain undetected.

Why it matters

Undetected errors or unauthorized routing changes could undermine transaction integrity, cause financial loss, disrupt payments, and damage customer trust.

Cause or gap

REC-02 is Pending beyond target. REC-03 is Closed without a documented resolution reason. PAY-CHG-01 lacks independent-review evidence. Technical implementation evidence for transaction controls is limited.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	5	15	High
Residual estimate	3	5	15	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

The narrative describes authorization, transaction references, and reconciliation. REC-01 is recorded as resolved with a documented resolution. Consistent follow-up, independent routing-change review, and technical enforcement remain unverified.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible undetected errors given delayed reconciliation and undocumented closure. Impact 5 assumes material payment-processing or routing errors could cause severe financial or service consequences. Transaction volumes, delay duration, technical enforcement, and actual independent review are unverified.

What needs to happen

Risk response

Reduce

Required action

Resolve REC-02 and retain dated follow-up. Document REC-03’s resolution reason. Obtain PAY-CHG-01 independent-review evidence or investigate the gap. Retain routing-change approvals and technical control-operation records.

Accountable owner	Target date
Payment Operations Owner, with Change Management Support	11/27/2026

Evidence references

E-012-01; E-012-02

R-012

Residual estimate

Security governance and responsibilities

High (12)

Related control

CTL-01

Status

Open

The risk and its impact

Risk scenario

Unclear accountability and delayed governance follow-up could leave security and third-party risks unassigned, unmonitored, or unresolved.

Why it matters

Unresolved governance and vendor-risk issues could allow weaknesses to persist, increasing exposure to security incidents or operational disruption.

Cause or gap

The RACI records third-party risk ownership as Shared / TBD and Accountability unclear. The policy/action summary states that the access-policy review and a High-priority committee action are overdue; actual dates are not supplied.

Risk estimate

Assessment	Likelihood (1-5)	Impact (1-5)	Score	Level
Inherent risk	3	4	12	High
Residual estimate	3	4	12	High

Inherent risk considers the scenario before safeguards. Residual risk is the estimate after considering existing safeguards.

Existing safeguards

Security leadership is assigned to Director Security, and the access policy is listed as Approved. Third-party accountability remains unclear, while policy review and committee follow-up have recorded exceptions.

Basis for the score

Assumptions and limits

Likelihood 3 reflects plausible unresolved risks from unclear accountability and recorded overdue actions. Impact 4 assumes governance weaknesses could materially affect security or operations. Actual due dates, policy requirements, and complete action tracking are unavailable, so lateness cannot be independently recalculated.

What needs to happen

Risk response

Reduce

Required action

Assign one accountable third-party risk owner. Obtain the policy and review schedule, complete the review, and close or formally reprioritize the committee action with an owner, target date, and documented approval.

Accountable owner

Director Security, with assigned Third Party Risk Owner

Target date

11/27/2026

Evidence references

E-001-01; E-001-02